

Identity, Authentication and Access Control

Ingabire Onesphore, M.S.

오네스

KYUNGSUNG UNIVERSITY

Three security decisions

1. Identity and accounts	How access can be compromised?
2. Passwords and MFA	Which control stops which attack?
3. Roles and permissions	Why this request should be allowed?

Case: Mina’s password was stolen

KYUNGSUNG UNIVERSITY

A stranger signs in as Mina, a student.

1	**Question 1**	Which security check accepted the stranger?
2	**Question 2**	Should the account be able to change grades?
3	**Question 3**	What evidence would you collect?

1. Identity and accounts

Account access depends on several separate checks.

Identification, authentication, authorization

KYUNG SUNG UNIVERSITY SINCE 1955
경성대학교
KYUNGSUNG UNIVERSITY

Check	Campus example	Meaning
Identification	“I am mina.student.”	An account claim
Authentication	The accepted proof matches.	Proof for that account
Authorization	Mina requests a grade edit.	Permission for that action

An accepted password can belong to the wrong person.

An account, a session, and a permission

KYUNG SUNG UNIVERSITY SINCE 1955
경성대학교
KYUNGSUNG UNIVERSITY

Item	Purpose	Failure example
Account record	Stores role, status and scope	A former TA stays active
Session	Recognizes later requests	A stolen session is reused
Permission check	Decides access to a resource	One student reads another’s data

A successful sign-in does not settle every later request.

Common routes into an account

KYUNG SUNG UNIVERSITY SINCE 1955
경성대학교
KYUNGSUNG UNIVERSITY

Route	What the attacker uses	A relevant defense
Password guessing	Likely password candidates	Attempt limits and strong passwords
Credential stuffing	A pair leaked from another site	A unique password per service
Phishing	A deceptive request for proof	Phishing-resistant authentication
Recovery or session abuse	A weak recovery path or stolen session	Secure recovery and session controls

The cost of guessing

KYUNG SUNG UNIVERSITY SINCE1955
경성대학교
KYUNGSUNG UNIVERSITY

10,000

Possible four-digit PINs

Includes leading zeroes.

1,000,000

Possible six-digit PINs

Time also depends on guessing rate and defenses.

Online guessing and offline guessing

KYUNG SUNG UNIVERSITY SINCE 1955
경성대학교
KYUNGSUNG UNIVERSITY

	Online	Offline
Where guesses go	To the login service	To a copied hash on the attacker's device
What can slow them	Server attempt limits and monitoring	A costly password-hashing scheme
Does login MFA help?	It can block account entry.	It does not prevent hash testing.

Activity: a hash as the target

KYUNG SUNG UNIVERSITY SINCE1955
경성대학교
KYUNGSUNG UNIVERSITY

A fictional database contains this SHA-256 value:

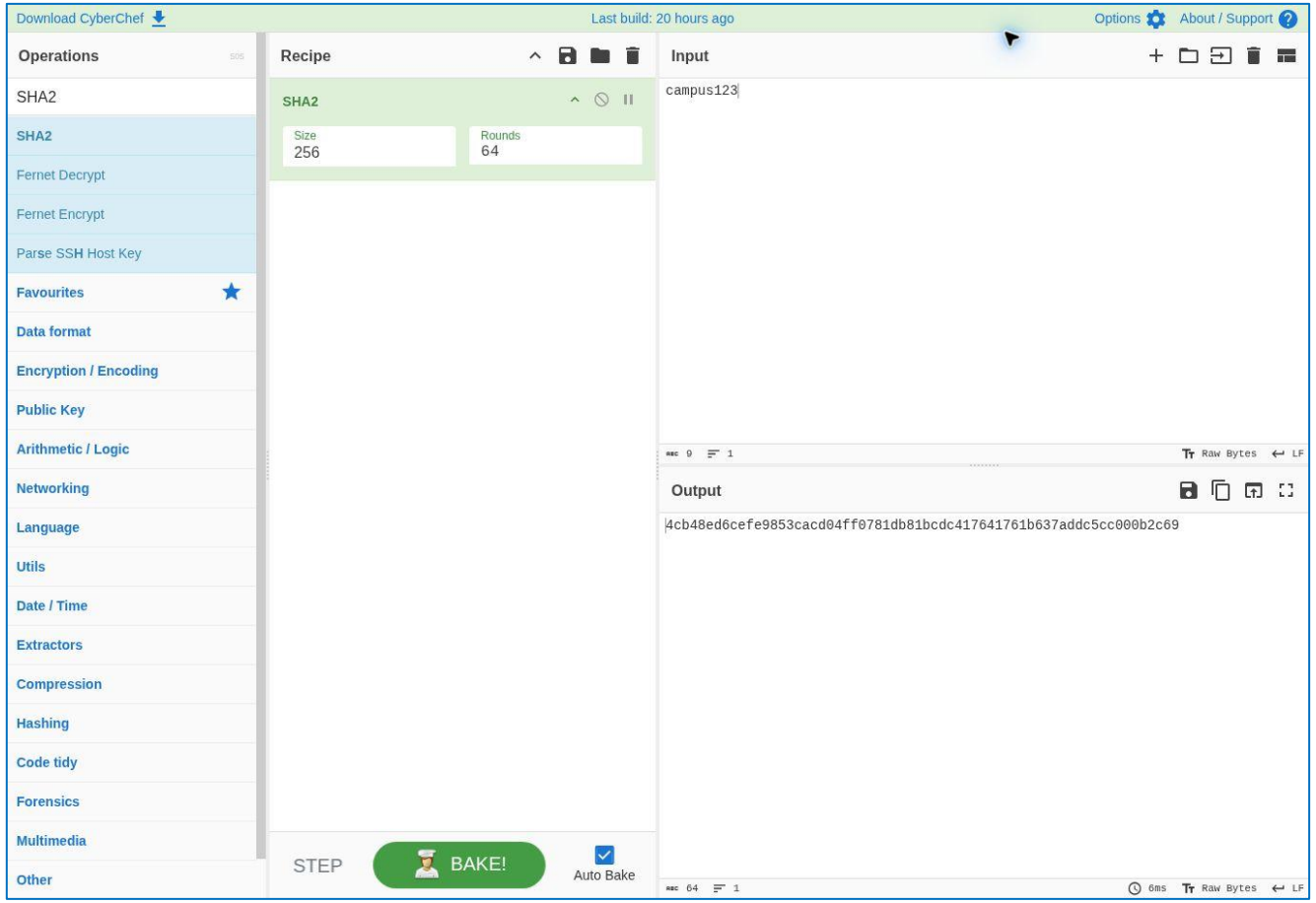
4cb48ed6cefe9853cacd04ff0781db81bcdc417641761b637addc5cc000b2c69

Candidate list (dictionary)

123456 password welcome campus123

Which candidate will produce the same full value?

Activity: candidate matching in CyberChef



Search for SHA2 and change size:
Size: 256
Rounds: 64

Try each candidate.
Compare the complete output with the target.

https://gchq.github.io/CyberChef/

Activity output: what the result establishes

Candidate	SHA-256	Full target match
123456	8d969eef6eca…	No
password	5e884898da28…	No
welcome	280d44ab1e9f…	No
campus123	4cb48ed6cefe…	Yes

The guess produced a match. The hash was not decrypted.

A failed short list would not prove that a password is safe.

Test your knowledge

KYUNG SUNG UNIVERSITY SINCE1955
경성대학교
KYUNGSUNG UNIVERSITY

1. Why can login rate limits fail to stop offline guessing?

2. How does credential stuffing differ from guessing?

3. A correct password opens someone else’s record.
   Which additional check failed?

2. Passwords and stronger proof

A strong sign-in needs both good credentials and correct enforcement.

Long, unique passwords

1	**Length**	Prefer a long, randomly generated password.
2	**Uniqueness**	Use a different password for each service.
3	**Predictability**	Campus2026! follows a recognizable pattern.

- **NIST SP 800-63B-4**: minimum 15 characters for password-only sign-in.
- A password **used within MFA** may have a minimum of 8.

A password manager makes uniqueness practical

KYUNG SUNG UNIVERSITY SINCE1955
경성대학교
KYUNGSUNG UNIVERSITY

1 **Generate** Create a different random password for each login.

2 **Store** Keep those passwords in a protected vault.

3 **Protect the vault** Use a strong master secret and available MFA.

Password storage that slows guessing

Storage choice	What it changes
Unique random salt per password	Identical passwords do not share a reusable hash.
A password-hashing scheme, such as Argon2id	Each guess consumes configured time and memory.
Fast SHA-256 alone, as in our demo	Allows rapid guesses and illustrates the weakness.

A salt is stored with the hash. It does not have to be secret.

Password reuse spreads one breach

KYUNG SUNG UNIVERSITY SINCE 1955 경성대학교 KYUNGSUNG UNIVERSITY

Fictional service	Password choice	After the forum password leaks
Student forum	Same password as the LMS	Forum access is at risk
LMS	Reused forum password	The leaked pair may work here too
Email	Different generated password	That leaked password does not match

MFA adds another check if a stolen password is tried.

MFA uses different factor types

There are usually three common factor types:	
Something you know	Password, PIN, security answer
Something you have	Phone, authenticator app, hardware security key
Something you are	Fingerprint, face recognition

Sign-in combination	Factor types	MFA?
Password and security question	Know + know	No
Password and authenticator-app code	Know + have	Yes
Security key activated with its PIN	Have + know	Yes

Two screens can still ask for the same kind of proof.

MFA methods face different attacks

Method or issue	What to remember
Typed one-time code	A deceptive site may relay it.
Unexpected approval prompt	Deny it and investigate through the official service.
Passkey or FIDO security key	Cryptographic proof binds authentication to the service.
Faulty server enforcement	The app may accept access before MFA is complete.

Activity: access before MFA is complete

PortSwigger lab: “2FA simple bypass”

1	**Starting condition**	The lab supplies a valid password. The second-factor code is unavailable.
2	**Prediction**	Will the protected account page open?

https://portswigger.net/web-security/authentication/multi-factor/lab-2fa-simple-bypass

Expected evidence

Observed stage	Expected in this vulnerable lab
Password stage	Accepted
Verification-code stage	No code supplied
Direct request for the protected page	Account page opens

The application failed to require completed MFA.

The protected route must check MFA state

Session state	Protected account page
No authenticated session	Deny or send to sign-in
Password accepted, MFA still pending	Require the second factor
MFA complete and permission valid	Allow this request

A verification screen alone does not enforce the rule.

Recovery and response also protect the account

KYUNG SUNG UNIVERSITY SINCE 1955
경성대학교 KYUNGSUNG UNIVERSITY

1	**Before an incident**	Protect recovery email and store backup codes securely.
2	**When access looks wrong**	Use the official service to change exposed credentials and revoke unfamiliar sessions.
3	**After containment**	Review recovery methods, MFA enrollment and activity.

3. Roles and permissions

Each request needs the right action, resource and scope.

One request, three policy questions

KYUNG SUNG UNIVERSITY SINCE 1955
경성대학교
KYUNGSUNG UNIVERSITY

1	**Subject**	Mina’s signed-in student account
2	**Action**	Read
3	**Resource**	Joon’s grade record in section B

Does the policy allow this subject to perform this action here?

Roles grant actions. Scope limits resources.

KYUNG SUNG UNIVERSITY SINCE 1955
경성대학교
KYUNGSUNG UNIVERSITY

Role	Read grades	Edit grades
Student	Own record	No
Teaching assistant	Assigned section	Assigned section
Lecturer	Assigned course	Assigned course
Disabled account	No	No

Horizontal and vertical access failures

KYUNG SUNG UNIVERSITY SINCE1955
경성대학교
KYUNGSUNG UNIVERSITY

Failure	Example	Missing boundary
Horizontal	Mina reads Joon’s record.	Another user’s resource
Vertical	A student changes course grades.	A more privileged action

Activity: another user's account data

PortSwigger lab: "User ID controlled by request parameter"

1	**Starting condition**	Signs in with the supplied test account.
2	**Prediction**	If the requested user ID changes, should the session be allowed to read that account?

https://portswigger.net/web-security/access-control/lab-user-id-controlled-by-request-parameter

The session and the resource differ

KYUNG SUNG UNIVERSITY SINCE 1955
경성대학교
KYUNGSUNG UNIVERSITY

Request	Signed-in account	Requested account
Original	wiener	wiener
Changed user ID	wiener	carlos

Expected vulnerable result: another account's API key appears.

The failed check concerns ownership of the requested resource.

Least privilege limits the possible damage

KYUNG SUNG UNIVERSITY SINCE1955
경성대학교
KYUNGSUNG UNIVERSITY

Assignment	Access needed	Access to deny
Student checks a result	Read own grade	Edit grades
TA grades section A	Edit assigned section	Edit section B
Lecturer teaches one course	Manage that course’s grades	Manage unrelated courses

Access changes when the assignment changes

1	**Join**	Create a personal account and approve required access.
2	**Change**	Replace old scope when duties or courses change.
3	**Leave**	Remove access and revoke applicable sessions.

A shared login makes individual accountability harder.

An access log reveals the failed boundary

KYUNG SUNG UNIVERSITY SINCE 1955
경성대학교
KYUNGSUNG UNIVERSITY

Time	Account	Event	Decision
10:01	mina.student	Password sign-in	Success
10:02	mina.student	Read Mina’s grade	Allow
10:03	mina.student	Read Joon’s grade	Allow
10:04	mina.student	Edit Joon’s grade	Deny

Which row conflicts with our policy? What can this log prove?

Three ideas to keep

KYUNG SUNG UNIVERSITY SINCE 1955 경성대학교 KYUNGSUNG UNIVERSITY

1	**Identity**	An account claim needs verified proof.
2	**Authentication**	Unique secrets and correctly enforced MFA protect sign-in.
3	**Authorization**	Every request needs permission within its allowed scope.



경성대학교
KYUNGSUNG UNIVERSITY

Thank You